

CLOUD PLATFORM STANDARD

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Cloud Platform Standard
Document ID	STD-CLD-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Standard is authorized by the Information Security Policy (POL-ISP-001) and implements the Access Control, Network Security, Encryption and Change Management Policies. It supports the SOC 2 Trust Services Criteria CC5.2, CC5.3, CC6.1, CC6.6, CC6.7, CC7.1, CC8.1 and CC9.1, and GDPR Article 32. It adopts published vendor and CIS benchmarks as its configuration baseline and states only the decisions those benchmarks cannot make for the Company.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 ADOPTED BASELINES6

6 DECISIONS THIS STANDARD MAKES.....7

7 EVALUATION AND EVIDENCE7

8 EXCEPTIONS8

9 REFERENCE.....8

1 DOCUMENT POLICY HISTORY8

1 Overview and Purpose

This Standard sets the configuration baseline for the Company's cloud platform. PromptHalo Technologies ("the Company") runs a small AWS estate alongside Google Workspace and GitHub, with almost everyone working remotely from their own laptop.

The Company does not write its own configuration rules where a published benchmark already exists and is maintained by the platform vendor or by CIS. It adopts those benchmarks by name and version as its baseline, which means the Company inherits the maintenance effort rather than carrying it.

What remains here is the short set of decisions a benchmark cannot make: how the Company's accounts are structured, what is prevented outright, how often configuration is evaluated, and what record that evaluation produces. Those are the parts SOC 2 tests, and they are the parts a benchmark is silent on.

This Standard configures the platform, which includes switching the log sources on. What happens to those records afterwards belongs to the Logging Standard and is not restated here.

2 Scope

This Standard applies to every AWS account in the Company's organization, to the Google Workspace tenant, and to the GitHub organization, including managed model and inference services.

It does not apply to personally owned devices, which are addressed in the Acceptable Use Policy. Where an adopted baseline requires a subscription tier the Company does not hold, the position is recorded as an exception with its compensating measure rather than left silent.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the "Accountable Party") owns this Standard, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this Standard and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. This Standard implements the Access Control, Network Security, Encryption and Change Management Policies. Where the two differ, the policy governs and this Standard is corrected at the next review. [SOC 2: CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this Standard.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this Standard.
2. **Adopted baseline** — an externally published configuration benchmark the Company has adopted by name and version as its own requirement.

3. **Baseline** — the configuration state this Standard requires, being the adopted benchmarks together with the decisions in Section 6.
4. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
5. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
7. **Guardrail** — an organization-level restriction that prevents a configuration rather than detecting it afterwards.
8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this Standard to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Adopted Baselines

The following are adopted by name and version as the Company's configuration baseline. Adopting a benchmark is what makes it the Company's own requirement; citing it loosely would not.

1. CIS Amazon Web Services Foundations Benchmark, current version, together with the AWS Foundational Security Best Practices standard, for the AWS estate. [SOC 2: CC7.1, CC6.6, CC6.7]
2. AWS Well-Architected Framework, Security Pillar, for architectural decisions not covered by the benchmarks above. [SOC 2: CC7.1, CC8.1]
3. CIS Google Workspace Foundations Benchmark, current version, for the Workspace tenant. [SOC 2: CC6.1, CC7.1]
4. GitHub's published organization and repository hardening guidance for the code estate. [SOC 2: CC6.1, CC8.1]
5. The adopted versions are confirmed annually and updated where the publisher has issued a new one. Where the Company declines a recommendation in an adopted baseline, that decision is

recorded as an exception with its reason and a review date — a benchmark adopted with silent departures is not a baseline. [SOC 2: CC5.3, CC7.1]

6 Decisions This Standard Makes

A benchmark can tell the Company how to configure an account. It cannot decide how many accounts there are, what is forbidden outright, or what evidence is produced. Those decisions are here.

1. The estate runs under a single AWS Organization, with production, non-production and log storage in separate accounts. Scope is then established by account boundary rather than by inspecting resources, and a compromised workload cannot reach the record of itself. [SOC 2: CC5.2, CC6.3, CC7.2]
2. The management account runs no workloads, root credentials carry hardware multi-factor authentication, and their use raises an alert. [SOC 2: CC6.1, CC7.2]
3. Service control policies prevent, at organization level, disabling CloudTrail, deleting log destinations, making storage public, and operating in regions the Company does not use. Prevention costs nothing to run and never forgets. [SOC 2: CC7.1, CC6.6]
4. People reach AWS through IAM Identity Center federated from the Company identity provider; workloads and agents use roles or their own identities, never a person's credentials. [SOC 2: CC6.1, CC6.2]
5. Confidential and Restricted information is encrypted at rest, with account-level defaults enabled so a resource created without thought is still encrypted, and secrets held in a managed secrets service rather than in source. [SOC 2: CC6.7 · GDPR Art. 32]
6. Internet-facing application endpoints sit behind a web application firewall with a maintained managed rule set, deployed in monitoring mode before enforcement. [SOC 2: CC6.6]
7. A current diagram shows accounts, environments, public entry points and trust boundaries, updated on material architecture change and confirmed annually. One page generated from the account structure is sufficient. [SOC 2: CC6.6, CC2.1]
8. Infrastructure is defined in code in the GitHub organization and changed through the same review and security-impact assessment as application code, so the environment can be rebuilt rather than recovered from memory. [SOC 2: CC8.1, CC9.1]

7 Evaluation and Evidence

Adopting a benchmark is not a control. Evaluating configuration against it, on a cadence, and recording the result is the control — and it is the part a service auditor sample.

1. Configuration is evaluated against the adopted baselines continuously using AWS Config with the CIS conformance pack and Security Hub, or by an equivalent open-source scanner run monthly where continuous evaluation is not cost-effective. [SOC 2: CC7.1]

2. Findings are triaged by severity, with critical and high addressed first. A finding accepted rather than fixed becomes an exception with a compensating measure and a review date. [SOC 2: CC7.1, CC5.3]
3. Drift from the baseline is treated as a change and follows the Change Management Policy rather than being corrected silently. [SOC 2: CC8.1, CC7.1]
4. The records these Standard produces are the adopted baseline versions, the evaluation output and triage record, the current architecture diagram with its revision date, and the exception register entries for anything not met. [SOC 2: CC2.1, CC5.3]

8 Exceptions

Where a requirement of an adopted baseline or of Section 6 cannot be met — a setting the Company's plan does not support, or a workload not yet at the baseline — the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

9 Reference

1. SOC 2 Trust Services Criteria, Security category [CC5.2, CC5.3, CC6.1, CC6.6, CC6.7, CC7.1, CC8.1, CC9.1]
2. CIS Amazon Web Services Foundations Benchmark
3. AWS Foundational Security Best Practices and Well-Architected Framework, Security Pillar
4. CIS Google Workspace Foundations Benchmark
5. GitHub organization and repository hardening guidance
6. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
7. STD-LOG-001 Logging Standard [SOC 2: CC7.2]
8. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.3]
9. POL-NET-001 Network Security Policy [SOC 2: CC6.6]
10. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
11. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
12. POL-BCP-001 Business Continuity Policy [SOC 2: CC9.1]
13. EU General Data Protection Regulation, Article 32

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release